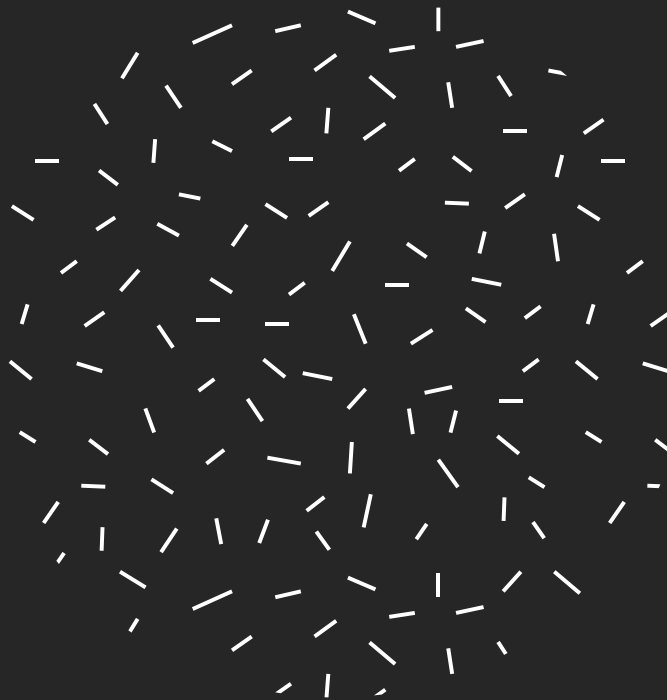




Company Name: LEAN TECHNOLOGIES KSA

Assessment Type: Grey Box Web/API VAPT

Report Type: Detailed Technical Report

Version: Nov-Dec 2025

Date: 18th December 2025

Contents

1.0	About SHELT	2
	Integrated Cyber Threat Intelligence.....	2
2.0	Executive Summary	3
3.0	Assessment Details.....	4
4.0	Scope of the Assessment.....	6
5.0	Assessment Methodology	7
	5.1 Risk Severity Rating.....	8
	Mappings to MITRE ATT&CK.....	11
	Mappings to OWASP Top 10	12
6.0	Risk Posture	13
	Summary of recommendations.....	13
7.0	Summary of Findings – API & Web Application.....	14
8.0	Vulnerability Details and Impact Assessment	16
	1. CORS Misconfiguration – Arbitrary Origin Allowed.....	16
	2. Information Disclosure in Frontend JavaScript (Hardcoded Secrets & Internal Configuration)	18
APPENDIX A		24
	Disclaimer	26

1.0 About SHELT

SHELT Global is a leading cybersecurity provider with a strong track record in Vulnerability Assessment and Penetration Testing (VAPT). We help organizations identify, analyze, and mitigate security weaknesses before they can be exploited.

Our expertise is backed by a globally recognized team of Certified Penetration Testers, Security Analysts, SOC Experts, Cyber Threat Intelligence Specialists, and Advisory Consultants. Our methodologies align with OWASP, MITRE ATT&CK, NIST, and ISO/IEC 27001:2022, ensuring comprehensive risk assessments and actionable remediation strategies.

With 24/7 Security Operations Centers (SOCs) in Cyprus, Nigeria, the Middle East, and Saudi Arabia, SHELT provides real-time threat intelligence and continuous security monitoring.

Integrated Cyber Threat Intelligence

Beyond VAPT, SHELT integrates cyber threat intelligence through our proprietary technology, REVA. By conducting advanced information gathering on LEAN TECHNOLOGIES as a service, we uncover potential attack vectors, exposed assets, and emerging threats before they can be exploited.

At SHELT, we don't just identify risks—we help you stay ahead of cyber threats and build a resilient security framework.

info@shelt.com
Markou tower, 2nd Floor.
Office 201, Strovolus, 2025
Nicosia, Cyprus

2.0 Executive Summary

This Vulnerability Assessment and Penetration Testing (VAPT) report presents the security evaluation of LEAN TECHNOLOGIES, conducted by SHELT Global to identify and mitigate potential cybersecurity risks. The assessment covered Internal Admin Portal, Web, External IPs, and API applications utilizing a combination of manual exploitation techniques and automated security tools to ensure a thorough evaluation.

Our analysis during the Nov/Dec 2025 engagement identified 1 Low and 1 Informational vulnerability, with key risks including misconfigurations and information disclosure. If exploited, these vulnerabilities could result in unauthorized access, data breaches, service disruptions, or other security compromises.

Findings have been classified based on industry standards, including OWASP, MITRE ATT&CK, and NIST, ensuring a structured risk evaluation. To enhance security posture, immediate remediation is advised for critical and high-severity vulnerabilities, while medium and low-risk issues should be addressed as part of a proactive security strategy.

In addition to VAPT, cyber threat intelligence insights were gathered using REVA, SHELT Global's proprietary reconnaissance technology, identifying potential external threats, exposed assets, and indicators of compromise related to LEAN TECHNOLOGIES. These insights provide a deeper understanding of the organization's exposure beyond internal assessments.

To mitigate the identified risks, SHELT Global recommends implementing patch management, secure configurations, access control enhancements, and continuous security monitoring. A detailed breakdown of discovered vulnerabilities, their impact, and remediation strategies is provided in the subsequent sections of this report.

Note: The findings in this report represent a **snapshot in time**, reflecting the security posture of the target systems during the testing window. Changes to the application, infrastructure, configurations, or exposure surface after the assessment date may introduce new risks not captured in this report.

SHELT Global remains committed to helping organizations strengthen their cybersecurity defenses and minimize exposure to cyber threats.

3.0 Assessment Details

The following is a list of the contacts and details engaged in this project. If you have any queries about the content of this report, please contact the appropriate project contacts.

Client's Contact

Title	Primary Contact	Primary Contact Email
Lean Technologies	Nasser Alshahrani	nasser.alshahrani@leantech.me

Assessment Project Team

Position	Assessor Name	Assessor Contact Email
Project Manager	Moe Sindos	msindos@shelt.com
Penetration Tester	Damian Pine	dpine@shelt.com
GRC Analyst	Azeez Rahmon	arahmon@shelt.com
Project Start Date	14 th of November 2025	
Project End Date	18 th of December 2025	

Document Control

Classification	CONFIDENTIAL
Report Name	Lean Technologies (KSA) Penetration Testing Report Nov-Dec 2025
Description	This report describes the security findings that were discovered during the Lean Technologies (KSA) Penetration Testing engagement. The PT was conducted on the internal admin, external sandbox, and production environments.
Submitted to	Nasser Alshahrani
Designation	CISO
Address	Hiteen District, 13516, Riyadh, Saudi Arabia
E-Mail	nasser.alshahrani@leantech.me

Document prepared by

Position	Name	Signature
Penetration Tester	Damian Pine	

Document reviewed & approved by:

Position	Name	Signature
Project Manager	Moe Sindos	<i>MoeSindos</i>

Confidentiality

This report contains highly confidential and private company information. As a result, this report should be utilized with the same sort of security and diligence as any other confidential document. This report should only be distributed to relevant entities only.

4.0 Scope of the Assessment

The External, Web, and API Application Penetration Testing engagement for LEAN TECHNOLOGIES was conducted from 14th of November 2025 to 7th of December 2025. The objective of the assessment was to evaluate the security posture of the Internal Admin Portal, External assets, APIs, and Web applications to identify any vulnerabilities that could potentially be exploited by attackers.

The predefined scope of the engagement, as agreed with the client, includes the following publicly accessible URLs, external IPs, and the shared web applications:

Description	URL
App Dashboard	https://dev.sa.leantech.me
Admin Portal	https://admin.sa01.leantech.me
Hosts	dev.sa.leantech.me link.sa.leantech.me app.sa.leantech.me hyperlink-api.sa.leantech.me api.sa.leantech.me link.sandbox.sa.leantech.me sandbox.sa.leantech.me hyperlink-api.sandbox.sa.leantech.me obksabank.sandbox.sa.leantech.me auth.sandbox.sa.leantech.me connect.sa.leantech.me auth.sa.leantech.me obksabank.leantech.me hyperlink-api.sa.leantech.me api2.sa.leantech.me
IP Addresses	108.139.200.65 193.122.82.235 108.158.46.120 193.122.82.235 193.122.65.127 193.122.82.235 100.111.185.242 100.111.200.65 207.127.97.182
APIs	https://sandbox.sa.leantech.me https://api.sa.leantech.me https://api2.sa.leantech.me https://link.sa.leantech.me

5.0 Assessment Methodology

The Vulnerability Assessment and Penetration Testing (VAPT) engagement followed a comprehensive and structured approach to evaluate the security posture of LEAN TECHNOLOGIES's Web and API applications. The methodology was designed to simulate real-world attack scenarios, using a combination of automated tools and manual techniques to identify vulnerabilities and security gaps.

The key phases of the assessment included:

1. Information Gathering:

Collection of publicly available information to understand the system architecture, exposed services, and potential attack vectors. This phase included active and passive reconnaissance using tools like REVA for advanced intelligence gathering.

2. Vulnerability Identification:

A thorough examination of the system to identify common vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), Insecure Authentication, etc., based on industry-standard vulnerability databases and testing techniques.

3. Exploitation:

Attempted exploitation of identified vulnerabilities to determine their potential impact and whether they could be leveraged for unauthorized access or disruption.

4. Post-Exploitation:

Analysis of the potential impact of successful exploitation, including escalation of privileges and data exfiltration possibilities.

5. Reporting:

Comprehensive documentation of findings, risk levels, impact, and detailed remediation steps based on the severity of the vulnerabilities.

6. Tools Used:

Nessus, Burp Suite, Nmap, Postman, Nikto, Ffuf, Shcheck, and Curl

The assessment adhered to leading cybersecurity frameworks such as OWASP Top 10, MITRE ATT&CK, NIST, and PTES, ensuring that the engagement followed recognized industry best practices.

5.1 Risk Severity Rating

To help LEAN TECHNOLOGIES prioritize findings, the findings and observations have been classified with threat severity rankings based on the standards below:

Vulnerability Metrics

The Common Vulnerability Scoring System (CVSS) is a method used to supply a qualitative measure of severity. **CVSS is not a measure of risk.** CVSS v2.0 and CVSS v3.x consist of three metric groups: Base, Temporal, and Environmental. CVSS v4.0 is a bit different and consists of Base, Threat, Environmental and Supplemental metric groups. Metrics result in a numerical score ranging from 0 to 10. A CVSS assessment is also represented as a vector string, a compressed textual representation of the values used to derive the score. Thus, CVSS is well suited as a standard measurement system for industries, organizations, and governments that need accurate and consistent vulnerability severity scores. Two common uses of CVSS are calculating the severity of vulnerabilities discovered on one's systems and as a factor in prioritization of vulnerability remediation activities. The National Vulnerability Database (NVD) provides CVSS enrichment for all published CVE records.

The NVD supports Common Vulnerability Scoring System (CVSS) v2.0, v3.x and v4.0 standards. However, per the [NVD CVSS v2.0 Retirement](#) announcement, we no longer provide CVSS v2.0 assessments for newly published CVE records. The NVD provides CVSS assessments of Base metrics the innate characteristics of each vulnerability. The NVD does not currently provide assessments for Temporal or Threat metrics (metrics that change over time due to events external to the vulnerability), Environmental metrics (metrics customized to reflect the impact of the vulnerability to a particular organization) or Supplemental metrics (metrics used to provide additional context). However, the NVD does supply a CVSS calculator for each version of CVSS to allow users to assess non-Base metrics.

The CVSS specifications are owned and managed by FIRST.Org, Inc. (FIRST), a US-based non-profit organization, whose mission is to help computer security incident response teams across the world. The official CVSS documentation can be found at <https://www.first.org/cvss/>.

[NVD - Vulnerability Metrics](#)

NVD CVSS Calculators

[NVD CVSS v2.0 Calculator](#)
[NVD CVSS v3.x Calculator](#)
[NVD CVSS v4.0 Calculator](#)

Qualitative Severity Ratings

CVSS v2.0 Ratings		CVSS v3.x Ratings		CVSS v4.0 Ratings	
Severity	Severity Score Range	Severity	Severity Score Range	Severity	Severity Score Range
		None*	0.0	None*	0.0
Low	0.0-3.9	Low	0.1-3.9	Low	0.1-3.9
Medium	4.0-6.9	Medium	4.0-6.9	Medium	4.0-6.9
High	7.0-10.0	High	7.0-8.9	High	7.0-8.9
		Critical	9.0-10.0	Critical	9.0-10.0

Severity		CVSS 3.1 Score	Description
S1	Critical	9.0 – 10.0	A critical risk designation involves quick remediation or mitigation. Exploiting these vulnerabilities requires minimal effort from the attacker but causes a serious risk to the confidentiality, integrity, and/or availability of the organization's systems and data. A successful hack of the ranking's findings results in access to systems and/or sensitive information.
S2	High	7.0 – 8.9	A high-risk rating involves swift action or mitigation. Exploiting these vulnerabilities requires minimal effort from the attacker but causes significant risks to the confidentiality, integrity, or availability of the organization's systems or data. A successful breach of this ranking's findings results in access to a single or restricted amount of sensitive information.
S3	Medium	4.0 – 6.9	A medium risk rating indicates efficient and acceptable remedial or mitigation measures. These discoveries may compromise non-privileged user accounts, reduce information system security, and even impact business continuity.
S4	Low	0.1 – 3.9	A low-risk ranking indicates remediation or mitigation once all higher priority findings have been addressed. These findings often expose information to unauthorized or anonymous users, and when combined with other attack paths, they can lead to more significant attacks.
S5	Informational	0.0	An informational risk rating does not represent a significant risk to the environment and may just contain discoveries that might provide useful information but do not expose the company to technical attacks. Findings classified as informational may be beneficial for an attacker acquiring information on the organization

			to utilize in subsequent attacks, such as social engineering or phishing.
--	--	--	---

Mappings to MITRE ATT&CK

This section of the report describes the tactics, techniques, and procedures outlined in the MITRE ATT&CK Framework. For more information on these tactics, techniques, and procedures (TTPs), SHELT advises that LEAN TECHNOLOGIES examine the URLs listed in the table below. In addition, SHELT has detailed how these TTPs were used throughout the penetration test.

MITRE ATT&CK®		
Name	Tactic	TTPID
Active Scanning	Reconnaissance	<u>T1595</u>
Gather Victim Host Information	Reconnaissance	<u>T1592</u>
Gather Victim Identity Information	Reconnaissance	<u>T1589</u>
Gather Victim Network Information	Reconnaissance	<u>T1590</u>
Gather Victim Org Information	Reconnaissance	<u>T1591</u>
Search Open Technical Databases	Reconnaissance	<u>T1596</u>
Search Open Websites/Domains	Reconnaissance	<u>T1593</u>
Search Victim-Owned Websites	Reconnaissance	<u>T1594</u>
Acquire Access	Resource Development	<u>T1650</u>
Compromise Accounts	Resource Development	<u>T1586</u>
Obtain Capabilities	Resource Development	<u>T1588</u>
Valid Accounts	Initial Access	<u>T1078</u>
Phishing	Initial Access	<u>T1566</u>
Exploit Public-Facing Application	Initial Access	<u>T1190</u>
File and Directory Discovery	Discovery	<u>T1083</u>
System Information Discovery	Discovery	<u>T1082</u>
Account Discovery	Discovery	<u>T1087</u>
Unsecured Credentials	Credential Access	<u>T1552</u>
Exploitation for Client Execution	Execution	<u>T1203</u>
Command and Scripting Interpreter	Execution	<u>T1059</u>
Weaken Encryption	Defense Evasion	<u>T1600</u>
Remote Services	Lateral Movement	<u>T1021</u>

Mappings to OWASP Top 10

This section of the report focuses on vulnerabilities categorized under the OWASP Top 10 framework. For each vulnerability identified, SHELT provides detailed insights into how these vulnerabilities were discovered, exploited, and their potential impact on the target environment during the penetration test. For a comprehensive understanding of the OWASP Top 10 categories and their implications, LEAN TECHNOLOGIES is encouraged to review the relevant resources outlined in the table below.

Additionally, SHELT has documented practical remediation strategies for each identified vulnerability to help enhance application security and mitigate risks effectively.

	
Name	Reference ID
Security Misconfiguration	A05:2021

Table 1-OWASP TOP 10

	
Name	Reference ID
Security Misconfiguration	API8:2023

Table 2 - OWASP API TOP 10

6.0 Risk Posture

Based on the evaluation results and the information provided above, the overall security posture of the evaluated systems inside the environment has been classified as Excellent. This shows that, while present security measures tend to be effective to combat most threats, there are small areas that need to be addressed to align with industry's best practices and reduce risk exposure.

All discovered medium, low, and informational-severity findings were marked as closed. Any open findings are unlikely to have a high impact on existing corporate operations. These remediations generally consist of technological changes and process upgrades that are well within LEAN TECHNOLOGIES' operational capacity to carry out without considerable overhead or impact on production.

To improve the organization's security maturity, it is recommended that all gaps be addressed while continuing to monitor and apply frequent updates to prevent emerging vulnerabilities.



Summary of recommendations

- All vulnerabilities and security issues discovered during the assessment have been fixed.
- Regularly perform security assessments, logging, and monitoring.

7.0 Summary of Findings – API & Web Application

During the Vulnerability Assessment and Penetration Testing (VAPT) engagement for LEAN TECHNOLOGIES Web application for the first cycle in May/June 2025, 4 vulnerabilities were identified across different components of the API and web application, ranging from Medium to Low risk levels, and for the second cycle in Nov/Dec 2025, 2 vulnerabilities were identified across different components of the API and web application, ranging from Low risk levels to Informational risk levels, and have now been all marked as closed. These findings were categorized and prioritized based on their potential impact on the organization's security posture.

Previously Discovered Vulnerabilities – May/June 2025		Severity Ratings		Status
M1	MFA Setup Bypass	P3	Medium (CVSS = 6.4)	Closed
M2	Identity Verification Endpoint Lacks Authorization	P3	Medium (CVSS = 6.3)	Closed
L1	Cross-Vendor Access Token Abuse if Customer UUID is Known	P4	Low (CVSS = 3.1)	Closed
L2	Unauthenticated Access to Entity Listings	P4	Low (CVSS = 3.0)	Closed

Table 2-Discovered Risks

Newly Discovered Vulnerabilities – Nov/Dec 2025		Severity Ratings		Status
L1	CORS Misconfiguration – Arbitrary Origin Allowed	P4	Low (CVSS = 2.9)	Open
I1	Information Disclosure in Frontend JavaScript	P5	Informational (CVSS = 0.0)	Open

Table 2-Discovered Risks

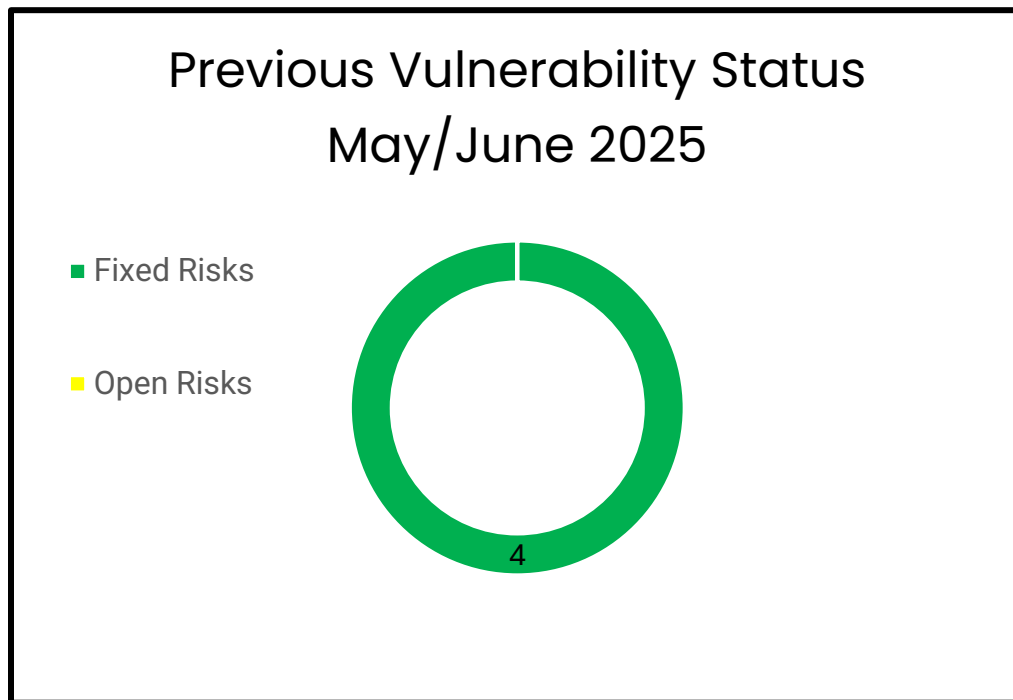


Figure 1 - Discovered Risks

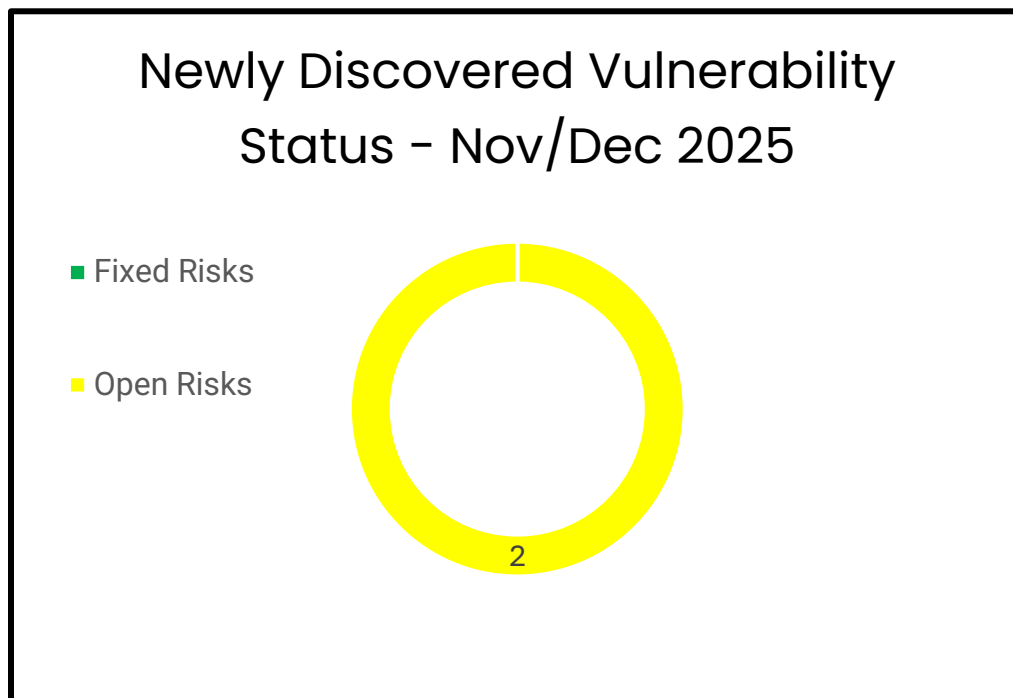


Figure 2 - Discovered Risks

8.0 Vulnerability Details and Impact Assessment

1. CORS Misconfiguration – Arbitrary Origin Allowed

Affected Asset	*.leantech.me
Severity	S4 - Low
CVSS Score	CVSS:3.1 - 2.9 /AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N
OWASP Category	A05:2021 – Security Misconfiguration API8:2023 – Security Misconfiguration
MITRE ATT&CK ID	T1185 – Browser Session Hijacking
Vulnerability Status	Not Exploitable
Status	Open

Summary

The application accepts arbitrary external origins in its CORS configuration and reflects them in the response without proper validation or restriction to trusted domains.

During testing, a crafted request containing the untrusted **origin** <https://shelt.com> was sent to a privileged webhook configuration endpoint. The server accepted the origin and returned it in the Access-Control-Allow-Origin response header, meaning any attacker-controlled or untrusted domain can make authenticated cross-origin requests on behalf of a user or system.

Proof of Concept

During the test, we tested several endpoints and added the Origin: <https://shelt.com> in the request header, and we received a response containing Access-Control-Allow-Origin: <https://shelt.com>, which confirms that the server **whitelists arbitrary external domains**.

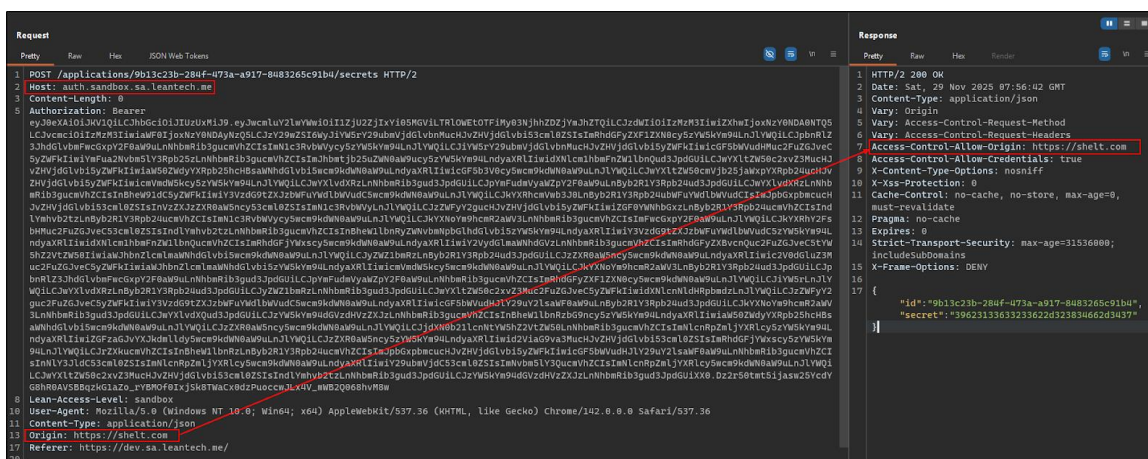


Figure 3: Reflected origin

Impact

While this is not immediately impactful, ***“The CORS behavior only reflects the host/origin in the response header. There is no demonstrated exploit where an attacker-controlled site can perform privileged actions or read sensitive data using this CORS configuration.”***

In exploitable conditions, this effectively enables Cross-Site Request Forgery, because CORS is what normally prevents these cross-domain interactions.

An attacker can:

- Create a malicious website
- Trick an authenticated user into visiting it
- Execute authenticated API requests via the user’s browser
- Modify webhook destinations without authorization
- Potentially redirect or intercept transaction/webhook data

Recommendation

We recommend the following:

1. Replace dynamic/reflective CORS with a **strict allowlist**:
 - E.g. <https://app.sa.learntech.me>, <https://dev.sa.learntech.me>
2. Disable Access-Control-Allow-Credentials for non-essential endpoints.

2. Information Disclosure in Frontend JavaScript (Hardcoded Secrets & Internal Configuration)

Affected Asset	https://dev.leantech.me/static/js/main.17e48155.js https://dev.sa.leantech.me/static/js/main.aabdf799.js https://cdn.leantech.me/link/sdk/web/latest/Lean.min.js
Severity	S5 - Informational
CVSS Score	CVSS:3.1 – 0.0 /AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N
OWASP Category	A05:2021 - Security Misconfiguration API8:2023 - Security Misconfiguration
MITRE ATT&CK ID	T1552 – Unsecured Credentials
Vulnerability Status	Not Exploitable
Status	Open

Summary

During analysis of publicly accessible JavaScript files served by the development portals, sensitive information and internal configuration data were discovered embedded within the frontend code.

The main application bundle exposed **hardcoded tokens, API keys, environment indicators, and internal service endpoints**, which should not be present in client-side resources.

The following request exposed sensitive configuration values:

GET /static/js/main.17e48155.js HTTP/2

Host: dev.leantech.me

Embedded in the JavaScript were hardcoded values such as:

- REACT_APP_SEGMENT_API_KEY
- REACT_APP_GROWTHBOOK_TOKEN
- Internal environment flags: REACT_APP_ENVIRONMENT:"production"
- Localhost and internal staging references
- References to internal OAuth, sandbox, and production services

Similarly, another application bundle returned sensitive values:

GET /static/js/main.aabdf799.js HTTP/2

Host: dev.sa.leantech.me

Which also exposed:

- GrowthBook clientKey and apiHost
- Hardcoded SDK tokens
- Embedded internal platform endpoints
- Internal environment routing data

Additionally, the following SDK file contained embedded secrets:

GET /link/sdk/web/latest/Lean.min.js HTTP/2

Host: cdn.leantech.me

Inside the minified code, the following types of data were visible:

- SDK/API keys
- Environment tags
- Version references
- Hardcoded service tokens
- Internal routing hints

These values provide attackers with intelligence about the application architecture and, in some cases, might grant direct access to internal feature systems if exploited (e.g., GrowthBook).

Note: While multiple subdomains were discovered in the JavaScript files, they are not listed here to avoid unnecessary exposure and risk amplification. The critical issue is the exposure of internal system structure and authentication tokens in frontend code, not the enumeration itself.

Proof of Concept

GET /static/js/main.17e48155.js HTTP/2

Host: dev.leantech.me

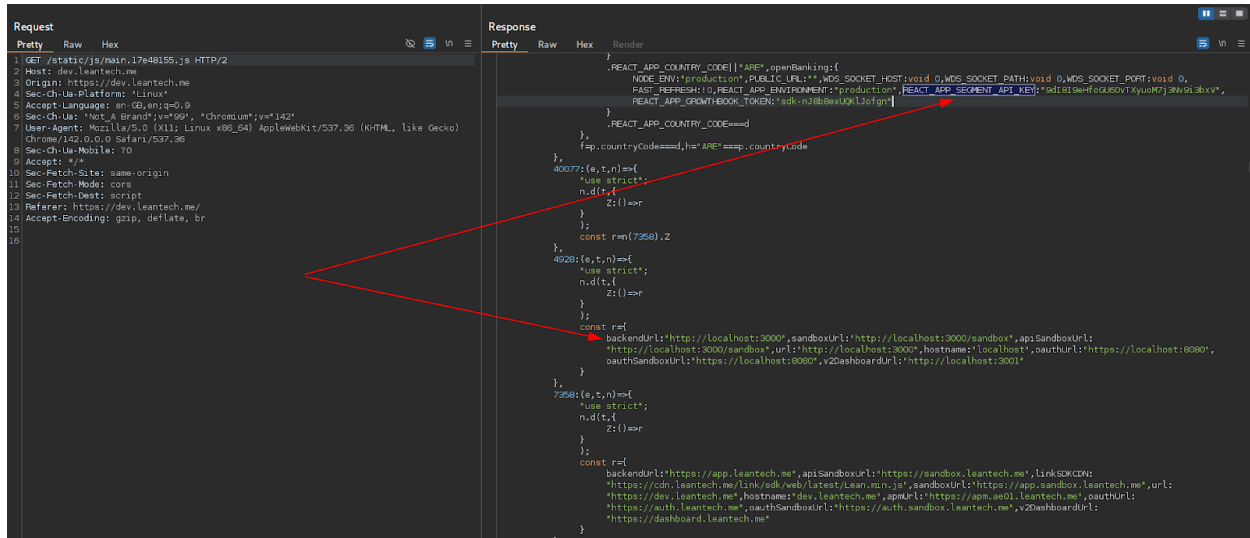


Figure 4: REACT_APP_SEGMENT_API_KEY

GET /static/js/main.aabdf799.js HTTP/2

Host: dev.sa.leantech.me

```
onClick():=>{
  const n=we.H.get(),r="localhost"==={
    NODE_ENV:"production",PUBLIC_URL:"",WDS_SOCKET_HOST:void 0,WDS_SOCKET_PATH:void 0,WDS_SOCKET_PORT:void 0,FAST_REFRESH:!0,REACT_APP_ENVIRONMENT:"sa01",
    REACT_APP_SEGMENT_API_KEY:"9dI8I9eHfoGU60vTXuoM7j3Nv9i3bxV",
    REACT_APP_GROWTHBOOK_TOKEN:"sdk-nJ8b8exUQKLJofgn",REACT_APP_COUNTRY_CODE:"SAU"
  }
  .REACT_APP_V2_ENV?Ce.Z.v2DashboardUrl:xe.Z.v2DashboardUrl;
  window.open('".concat(r,"?").concat(new URLSearchParams({
    access_token:n||"",environment:e,app_token:t
  })), "_blank")
},
```

Figure 5 - REACT_APP_GROWTHBOOK_TOKEN

```
var r=n(1413);
const a=new(n(71936).Gr)({
  apiHost:"https://cdn.growthbook.io",clientKey:"sdk-nJ8b8exUQKLJofgn",enableDevMode:!1,
  debug:!1
});
```

Figure 6: clientKey

Request	Response
<pre> 1 GET /static/js/main.aabdf799.js HTTP/2 2 Host: dev.sa.lean.tech.me 3 Origin: https://dev.sa.lean.tech.me 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Not_A Brand";v="99", "Chromium";v="102" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/102.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: */* 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: cors 12 Sec-Fetch-Dest: script 13 Referer: https://dev.sa.lean.tech.me/ 14 Accept-Encoding: gzip, deflate, br 15 16 </pre>	<pre> 4928:(e,t,n)=>{ "use strict"; n.d(t,{ Z:()=>r }); }; const r={ backendUrl:"http://localhost:3000",sandboxUrl:"http://localhost:3000/sandbox", apiSandboxUrl:"http://localhost:3000/sandbox",url:"http://localhost:3000", hostname:"localhost",oauthUrl:"https://localhost:8080",oauthSandboxUrl: "https://localhost:8080",v2DashboardUrl:"http://localhost:3001" }, 7358:(e,t,n)=>{ "use strict"; n.d(t,{ Z:()=>r }); }; const r={ backendUrl:"https://app.lean.tech.me",apiSandboxUrl: "https://sandbox.lean.tech.me",linkSDKCDN: "https://cdn.lean.tech.me/link/sdk/web/latest/Lean.min.js",sandboxUrl: "https://app.sandbox.lean.tech.me",url:"https://dev.lean.tech.me",hostname: "dev.lean.tech.me",apiUrl:"https://api.ae01.lean.tech.me",oauthUrl: "https://auth.lean.tech.me",oauthSandboxUrl:"https://auth.sandbox.lean.tech.me", v2DashboardUrl:"https://dashboard.lean.tech.me" } </pre>

Figure 7: BackendUrl

Request	Response
<pre> 1 GET /static/js/main.aabdf799.js HTTP/2 2 Host: dev.sa.lean.tech.me 3 Origin: https://dev.sa.lean.tech.me 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Not_A Brand";v="99", "Chromium";v="102" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/102.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: */* 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: cors 12 Sec-Fetch-Dest: script 13 Referer: https://dev.sa.lean.tech.me/ 14 Accept-Encoding: gzip, deflate, br 15 16 </pre>	<pre> } const r={ backendUrl:"https://app.ae02.lean.tech.me",apiSandboxUrl: "https://sandbox.ae02.lean.tech.me",linkSDKCDN: "https://cdn.lean.tech.me/link/sdk/web/staging/ae/latest/Lean.min.js", sandboxUrl:"https://app.sandbox.ae02.lean.tech.me",url: "https://dev.ae02.lean.tech.me",hostname:"dev.ae02.lean.tech.me",apiUrl: "https://api.ae02.lean.tech.me",oauthUrl:"https://auth.ae02.lean.tech.me", oauthSandboxUrl:"https://auth.sandbox.ae02.lean.tech.me",v2DashboardUrl: "https://dashboard.ae02.lean.tech.me" }, 37736:(e,t,n)=>{ "use strict"; n.d(t,{ Z:()=>r }); }; const r={ backendUrl:"https://app.ae03.lean.tech.me",apiSandboxUrl: "https://sandbox.ae03.lean.tech.me",linkSDKCDN: "https://cdn.lean.tech.me/link/sdk/web/dev/ae/latest/Lean.min.js",sandboxUrl: "https://app.sandbox.ae03.lean.tech.me",url:"https://dev.ae03.lean.tech.me", hostname:"dev.ae03.lean.tech.me",apiUrl:"https://api.ae03.lean.tech.me",oauthUrl: "https://auth.ae03.lean.tech.me",oauthSandboxUrl: "https://auth.sandbox.ae03.lean.tech.me",v2DashboardUrl: "https://dashboard.ae03.lean.tech.me" } </pre>

Figure 8: BackendUrl

Request	Response
<pre> 1 GET /static/js/main.aabdf799.js HTTP/2 2 Host: dev.sa.lean.tech.me 3 Origin: https://dev.sa.lean.tech.me 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Not_A Brand";v="99", "Chromium";v="102" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/102.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: */* 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: cors 12 Sec-Fetch-Dest: script 13 Referer: https://dev.sa.lean.tech.me/ 14 Accept-Encoding: gzip, deflate, br 15 16 </pre>	<pre> const r={ backendUrl:"https://app.sa.lean.tech.me",apiSandboxUrl: "https://sandbox.sa.lean.tech.me",linkSDKCDN: "https://cdn.lean.tech.me/link/sdk/web/latest/Lean.min.js",sandboxUrl: "https://app.sandbox.sa.lean.tech.me",url:"https://dev.sa.lean.tech.me",hostname: "dev.sa.lean.tech.me",hyperlinkBackendUrl: "https://hyperlink-api.sa.lean.tech.me",hyperlinkSandboxBackendUrl: "https://hyperlink-api.sandbox.sa.lean.tech.me",oauthUrl: "https://auth.sa.lean.tech.me",oauthSandboxUrl: "https://auth.sandbox.sa.lean.tech.me",linkApiUrl:"https://link.sa.lean.tech.me", linkSandboxApiUrl:"https://link.sandbox.sa.lean.tech.me",linkSDKv2CDN: "https://cdn.lean.tech.me/link/sdk/web/v2/prod/sa/latest/Lean.min.js", v2DashboardUrl:"https://dashboard.sa.lean.tech.me" }, 77755:(e,t,n)=>{ "use strict"; n.d(t,{ Z:()=>r }); }; const r={ backendUrl:"https://app.sa02.lean.tech.me",apiSandboxUrl: "https://sandbox.sa02.lean.tech.me",linkSDKCDN: "https://cdn.lean.tech.me/link/sdk/web/staging/sa/latest/Lean.min.js", sandboxUrl:"https://app.sandbox.sa02.lean.tech.me",url: "https://dev.sa02.lean.tech.me",hostname:"dev.sa02.lean.tech.me", hyperlinkBackendUrl:"https://hyperlink-api.sa02.lean.tech.me", hyperlinkSandboxBackendUrl:"https://hyperlink-api.sa02.lean.tech.me",oauthUrl: "https://auth.sa02.lean.tech.me",oauthSandboxUrl: "https://auth.sandbox.sa02.lean.tech.me",linkApiUrl:"https://link.sa02.lean.tech.me", linkSandboxApiUrl:"https://link.sandbox.sa02.lean.tech.me",linkSDKv2CDN: "https://cdn.lean.tech.me/link/sdk/web/v2/staging/sa/latest/Lean.min.js", v2DashboardUrl:"https://dashboard.sa02.lean.tech.me" } </pre>

Figure 9: BackendUrl

GET /link/sdk/web/latest/Lean.min.js HTTP/2

Host: cdn.leantech.me

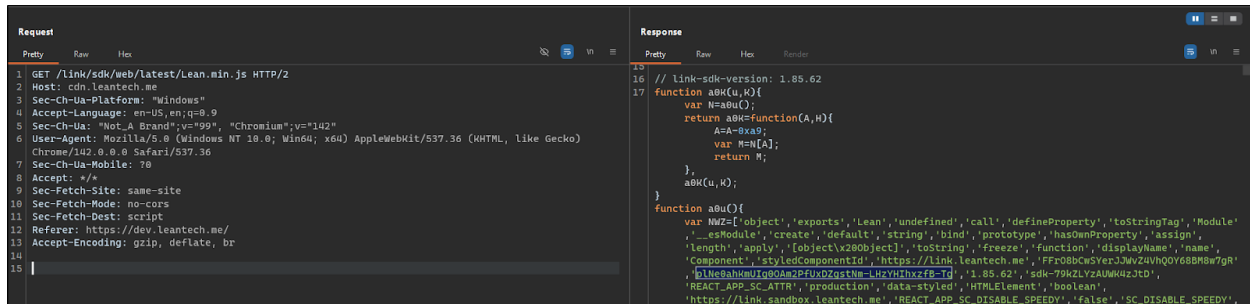


Figure 10: SDK/API keys

Impact

While this is not immediately impactful, LeanTech confirmed and states that ***“After internal discussions, the disclosed values were confirmed to be non-sensitive, and their presence does not introduce risk.”***

In exploitable conditions, an attacker can combine with other vulnerabilities to escalate the impact:

- Extract valid **third-party service tokens**
- Query internal systems, such as **GrowthBook feature management** if exploitable
- Identify internal service architecture and routing
- Perform targeted attacks against internal endpoints
- Bypass security assumptions through environmental knowledge
- Chain with other vulnerabilities (CORS or IDOR)

This significantly reduces the attacker’s reconnaissance effort and increases the likelihood of a successful targeted attack.

Recommendation

We recommend the following:

1. Immediately revoke & rotate all exposed:
 - Segment API keys
 - GrowthBook SDK tokens
 - Any clientKey or SDK tokens found in bundles

2. Remove all secret material from the frontend build process.
3. Store keys only in:
 - Backend environment variables
 - Secret managers (Vault, SSM, etc.)

APPENDIX A

Tested URL	
1.	https://dev.sa.learntech.me
2.	https://admin.sa01.learntech.me
3.	https://link.sa.learntech.me
4.	https://app.sa.learntech.me
5.	https://hyperlink-api.sa.learntech.me
6.	https://api.sa.learntech.me
7.	https://link.sandbox.sa.learntech.me
8.	https://sandbox.sa.learntech.me
9.	https://hyperlink-api.sandbox.sa.learntech.me
10.	https://obksabank.sandbox.sa.learntech.me
11.	https://auth.sandbox.sa.learntech.me
12.	https://connect.sa.learntech.me
13.	https://auth.sa.learntech.me
14.	https://obksabank.learntech.me
15.	https://hyperlink-api.sa.learntech.me
16.	https://api2.sa.learntech.me
17.	https://sandbox.sa.learntech.me
18.	https://api.sa.learntech.me
19.	https://api2.sa.learntech.me
20.	https://link.sa.learntech.me

Tested Assets	
1.	Sandbox Environment
2.	Production Environment
3.	108.139.200.65
4.	100.111.200.65
5.	108.158.46.120
6.	193.122.82.235
7.	207.127.97.182
8.	193.122.65.127
9.	193.122.82.235
10.	100.111.185.242
11.	193.122.82.235

Tester Created Credentials		
Test Vendor 1	dpine+ksavendor1@shelt.com	(Sandbox)
Test Vendor 1	dpine+ksavendor2@shelt.com	(Sandbox)
Test Vendor 2	dpine+ksaprod1@shelt.com	(Production)
Test Vendor 2	dpine+ksaprod2@shelt.com	(Production)

Tester Uploaded files/malwares	
Test file	N/A
Web shell	N/A

Note: All test uploaded files are to be removed, credentials and tokens to be deactivated immediately after testing. Sensitive data was handled securely and redacted in this report if applicable.



Disclaimer

This document is intended only for the use of the individual or entity to which it is addressed and may contain information that is privileged, confidential and exempt from disclosure under applicable law. If the reader of this disclaimer is not the intended recipient, you are hereby notified that any dissemination, distribution or copying of this document is strictly prohibited. If you received this document in error, please notify us immediately by telephone and return the original document to us at the post address below.